

Report Esercizio Malware - Analisi Statica

PE

S9L2

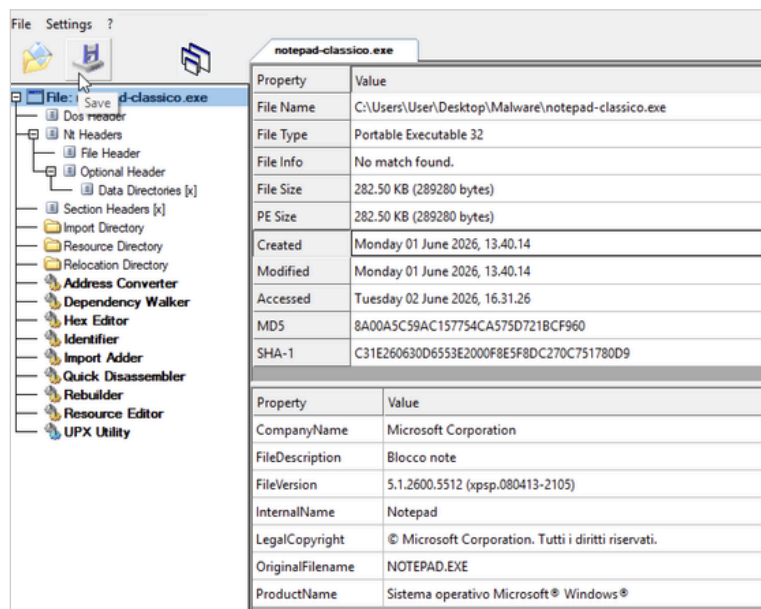
1. Obiettivo

La seguente esercitazione prevede l'analisi statica del file eseguibile **notepad-classico.exe** presente nella cartella Malware della FlareVM. L'obiettivo è identificare le **librerie importate** (Import Table) e le **sezioni PE** (Section Headers) del file, fornendo per ciascuna una descrizione tramite analisi AI, al fine di valutare il profilo di rischio del campione prima di qualsiasi esecuzione.

Nota: L'analisi è condotta in modalità **statica** quindi il file non viene eseguito. Il tool utilizzato è **CFF Explorer** (NTCore), preinstallato in FlareVM. Tutte le attività sono svolte in ambiente virtuale isolato a fini didattici.

2. Informazioni sul File

File analizzato	notepad-classico.exe
Path	C:\Users\User\Desktop\Malware\notepad-classico.exe
File Type	Portable Executable 32 (PE32)
File Size	282.50 KB (289.280 bytes)
MD5	8A00A5C59AC157754CA575D721BCF960
SHA-1	C31E260630D6553E2000F8E5F8DC270C751780D9
Creato	Monday 01 June 2026, 13:40:14
Tool di analisi	CFF Explorer (NTCore) - FlareVM



CFF Explorer - Informazioni file e metadata notepad-classico.exe

Red Flag - Metadata spoofing: Il file dichiara di essere **Notepad di Windows XP** (versione 5.1.2600.5512, build xpsp.080413-2105, CompanyName: Microsoft Corporation, OriginalFilename: NOTEPAD.EXE) ma risulta **creato il 01 Giugno 2026**. Un eseguibile autentico di Windows XP non può essere stato creato nel 2026. Questo è un classico caso di **Masquerading (MITRE ATT&CK T1036)**: il malware impersona un'applicazione legittima per eludere la rilevazione.

3. Librerie Importate (Import Table)

La Import Address Table (IAT) elenca le DLL di sistema che il malware carica all'avvio e le funzioni che utilizza. L'analisi delle librerie importate permette di inferire le capacità del malware ancora prima di eseguirlo. Sono state identificate **9 librerie** per un totale di **201 funzioni importate**.

notepad-classico.exe						
Module Name	Imports	OFTs	TimeStamp	ForwarderChain	Name RVA	FTs (IAT)
szAnsi	(nFunctions)	Dword	Dword	Dword	Dword	Dword
comdlg32.dll	9	000400C8	00000000	FFFFFFFF	00040410	000012C4
SHELL32.dll	4	000400F0	00000000	FFFFFFFF	000404B5	00001174
WINSPOOL.DRV	3	00040104	00000000	FFFFFFFF	00040502	000012B4
COMCTL32.dll	1	00040114	00000000	FFFFFFFF	00040543	00001020
msvcrt.dll	22	0004011C	00000000	FFFFFFFF	00040566	000012EC
ADVAPI32.dll	7	00040178	00000000	FFFFFFFF	0004068A	00001000
KERNEL32.dll	57	00040198	00000000	FFFFFFFF	0004070F	0000108C
GDI32.dll	24	00040280	00000000	FFFFFFFF	00040AF1	00001028
USER32.dll	74	000402E4	00000000	FFFFFFFF	00040C5F	00001188

CFF Explorer - Import Directory: le 9 librerie importate da notepad-classico.exe

Libreria	Import	Descrizione (analisi AI)
<i>USER32.dll</i>	74	Libreria core di Windows per la gestione dell'interfaccia grafica utente (GUI). Fornisce funzioni per la creazione e gestione di finestre, messaggi, input da tastiera e mouse, dialog box e controlli UI. Il numero elevato di import (74) è coerente con un'applicazione con interfaccia grafica, ma può anche indicare interazioni estese con il desktop dell'utente a fini malevoli (keylogging, screen capture, window enumeration).
<i>KERNEL32.dll</i>	57	Libreria fondamentale del kernel di Windows. Gestisce operazioni di basso livello: gestione della memoria, processi e thread, file system, sincronizzazione e I/O. Con 57 import è la DLL più chiamata dopo USER32 - un numero così elevato in un presunto Notepad è anomalo e suggerisce operazioni di sistema avanzate (process injection, file manipulation, memory allocation).
<i>GDI32.dll</i>	24	Graphics Device Interface, una libreria per il rendering grafico di Windows. Gestisce font, pennelli, bitmap e operazioni di disegno su device context. Presente legittimamente in un editor di testo, ma 24 import sono nella media alta per un semplice Notepad.
<i>msvcrt.dll</i>	22	Microsoft Visual C++ Runtime Library - fornisce le funzioni standard del linguaggio C (malloc, printf, strcpy, fopen, ecc.). La sua presenza indica che il binario è compilato in C/C++. 22 import sono nella norma per applicazioni Windows native.
<i>comdlg32.dll</i>	9	Common Dialog Box Library - fornisce le dialog box standard di Windows: apertura/salvataggio file, selezione colore/font, stampa. Coerente con un editor di testo (File → Apri, Salva con nome). 9 import sono plausibili per questa DLL.
<i>ADVAPI32.dll</i>	7	Advanced Windows API - gestisce sicurezza, crittografia, registro di sistema (Registry) e servizi Windows. La presenza di questa DLL in un Notepad è SOSPETTA: un editor di testo base non ha bisogno di accedere al registro o gestire token di sicurezza. Indica potenziali operazioni su HKCU/HKLM (persistenza, raccolta dati).
<i>SHELL32.dll</i>	4	Windows Shell Library - fornisce funzionalità della shell di Windows: esecuzione di applicazioni (ShellExecute), operazioni su file e icone. ShellExecute è spesso usata dal malware per lanciare processi o aprire URL. 4 import meritano analisi delle funzioni specifiche chiamate.
<i>WINSPOOL.DRV</i>	3	Windows Spooler Driver - gestisce la stampa e la comunicazione con le stampanti. Presente nel Notepad originale di Windows XP per la funzione di stampa. 3 import sono compatibili con l'uso legittimo (OpenPrinter, GetPrinter, ecc.).
<i>COMCTL32.dll</i>	1	Common Controls Library - fornisce controlli UI avanzati come toolbar, listview, treeview e status bar. 1 solo import suggerisce un uso minimo, probabilmente InitCommonControls per inizializzare i controlli comuni.

Osservazione AI: La combinazione **KERNEL32.dll (57) + USER32.dll (74) + ADVAPI32.dll (7) + SHELL32.dll (4)** suggerisce capacità ben oltre quelle di un semplice editor di testo: manipolazione di processi e memoria, accesso al registro di sistema, esecuzione di comandi shell e interazione estesa con l'interfaccia utente. ADVAPI32 in particolare è anomala per Notepad e indica potenziali operazioni su chiavi di registro (persistenza) o token di sicurezza.

4. Sezioni PE (Section Headers)

Le sezioni PE definiscono la struttura interna del file eseguibile. Ogni sezione ha un nome, dimensioni virtuali/raw e caratteristiche (flag) che ne determinano i permessi in memoria (lettura, scrittura, esecuzione). Sono state identificate **6 sezioni**, di cui **2 altamente anomale** (evidenziate in rosso/arancio nella tabella).

Name	Virtual Size	Virtual Address	Raw Size	Raw Address	Reloc Address	Linenumbers	Relocations N...	Linenumbers ...	Characteristics
Byte[3]	Dword	Dword	Dword	Dword	Dword	Dword	Word	Word	Dword
.text	00007748	00001000	00007000	00004000	00000000	00000000	0000	0000	60000020
.data	00001BA8	00009000	00000800	00007C00	00000000	00000000	0000	0000	C0000040
.rsrc	00008DB4	0000B000	00000E00	00006400	00000000	00000000	0000	0000	40000040
.text	0002B6AC	00014000	00028800	00011200	00000000	00000000	0000	0000	E0000020
.idata	0000113E	00040000	00001000	0003CA00	00000000	00000000	0000	0000	C2000040
.rsrc	00008DB0	00042000	00000E00	0003C000	00000000	00000000	0000	0000	40000040

CFF Explorer - Section Headers: le 6 sezioni PE del campione

Sezione	Virt. Size	Virt. Addr	Characteristics	Descrizione (AI)
.text	00007748	00001000	60000020	Prima sezione codice che contiene il codice eseguibile principale del programma (istruzioni macchina x86). Virtual Size 0x7748 (~30KB). Caratteristiche 0x60000020: CODE + EXECUTE + READ, normale per una sezione codice. Dimensione compatibile con un piccolo programma come Notepad XP.
.data	00001BA8	00009000	C0000040	Sezione dati inizializzati che contiene variabili globali e statiche con valore iniziale. Virtual Size 0x1BA8 (~7KB). Caratteristiche 0xC0000040: READ + WRITE + INITIALIZED_DATA. Presente in ogni PE normale.
.rsrc	00008DB4	0000B000	40000040	Prima sezione risorse che contiene le risorse embedded del programma: icone, stringhe, dialog template, menu, bitmap. Virtual Size 0x8DB4 (~36KB). Caratteristiche 0x40000040: READ + INITIALIZED_DATA. Normale per un'applicazione con GUI.
.text	0002B6AC	00014000	E0000020	ANOMALIA CRITICA - Seconda sezione .text. Avere due sezioni con lo stesso nome è altamente insolito nei PE legittimi e rappresenta un RED FLAG significativo. Virtual Size 0x2B6AC (~177KB) di dimensione enormemente superiore alla prima .text. Caratteristiche 0xE0000020: CODE + EXECUTE + READ + WRITE in combinazione a EXECUTE+WRITE su una sezione codice è anomala e tipica di malware packed/self-modifying: il codice si decompone o modifica in memoria a runtime.
.idata	0000113E	00040000	C2000040	Import Address Table che contiene i puntatori alle funzioni importate dalle DLL. Virtual Size 0x113E (~4KB). Caratteristiche 0xC2000040 presentano un flag insolito (bit 0x20000000 = MEM_DISCARDABLE oppure flag non standard). Normalmente .idata ha caratteristiche 0xC0000040. La variazione merita attenzione.
.rsrc	00008DB0	00042000	40000040	ANOMALIA - Seconda sezione .rsrc. Come per la doppia .text, avere due sezioni risorse è atipico. Potrebbe contenere risorse aggiuntive nascoste, payload cifrati o dati usati dal malware a runtime mascherati come risorse. Virtual Size 0x8DB0 (~36KB), praticamente identica alla prima .rsrc.

Red Flag con Doppia sezione .text con flag WRITE+EXECUTE: La presenza di **due sezioni .text** e **due sezioni .rsrc** è atipica nei PE legittimi. In particolare, la seconda .text (VA 0x14000, dimensione ~177KB, caratteristiche E0000020) ha i flag **EXECUTE + READ + WRITE** combinati ad una configurazione anomala che indica codice **self-modifying** o **packed**: il malware si decompone in questa sezione a runtime prima dell'esecuzione. Questa tecnica è usata per eludere l'analisi statica e l'antivirus.

5. Considerazione Finale (Analisi AI)

L'analisi statica di notepad-classico.exe rivela un profilo di rischio **elevato**. Il campione si presenta come il Blocco Note di Windows XP ma presenta molteplici indicatori di compromissione:

IOC 1 Masquerading (MITRE T1036)

Metadata falsificati: CompanyName Microsoft, OriginalFilename NOTEPAD.EXE, versione XP 5.1.2600 ma creato il 01/06/2026. Tecnica classica per ingannare utenti e sistemi di difesa basati su firma.

IOC 2 Packed/Self-Modifying Code (MITRE T1027)

La seconda sezione .text con caratteristiche EXECUTE+WRITE (~177KB) suggerisce un payload compresso o cifrato che si decompone in memoria a runtime. Il flag UPX Utility nel menu di CFF Explorer conferma la presenza di packing.

IOC 3 Capacità anomale per un editor di testo

ADVAPI32.dll (registro + sicurezza), SHELL32.dll (esecuzione processi), KERNEL32.dll con 57 import (manipolazione memoria/processi) non sono giustificabili per un semplice Notepad. Indicano potenziali capacità di persistenza su registro, lateral movement e process injection.

Conclusione AI: Con alta probabilità notepad-classico.exe è un **trojan camuffato da Notepad** con tecniche di packing/offuscamento. Prima dell'analisi dinamica è consigliabile: (1) ripristinare lo snapshot Clean della FlareVM, (2) isolare la VM dalla rete, (3) avviare il processo monitorando con **Process Monitor** e **Wireshark** per osservare le azioni reali a runtime.

6. Riepilogo Indicatori di Rischio

Indicatore	Dettaglio	MITRE ATT&CK	Rischio
Metadata spoofing	Notepad XP 2026	T1036 - Masquerading	Alto
2x sezione .text	EXECUTE+WRITE su 2a .text	T1027 - Obfuscated Files	Critico
2x sezione .rsrc	Doppia risorsa - payload nascosto?	T1027 - Packing	Alto
ADVAPI32.dll	Registry + Security token access	T1547 - Run Key Persistence	Alto
SHELL32.dll	ShellExecute - esecuzione processi	T1059 - Command Execution	Medio

DISCLAIMER: Tutte le tecniche descritte sono state applicate esclusivamente in ambiente virtuale isolato (FlareVM su UTM) a fini didattici. L'utilizzo non autorizzato su sistemi reali è illegale ai sensi del Codice Penale italiano (art. 615-ter, 635-bis, 617-quater).